

PRIVACY & SECURITY BY DESIGN

An Evidence-Based Review: Impact analysis of embedded DPO, AppSec, and GRC roles in the SGraph Send Agentic Project.



METADATA

DATE: 16 Feb 2026
SOURCE: Evidence Pack v0.4.4
REPORT BY: Project Lead & Historian Agent
STATUS: Verified

THE CHALLENGE: MOVING FROM THEORY TO RECEIPTS

THE **HYPOTHESIS**

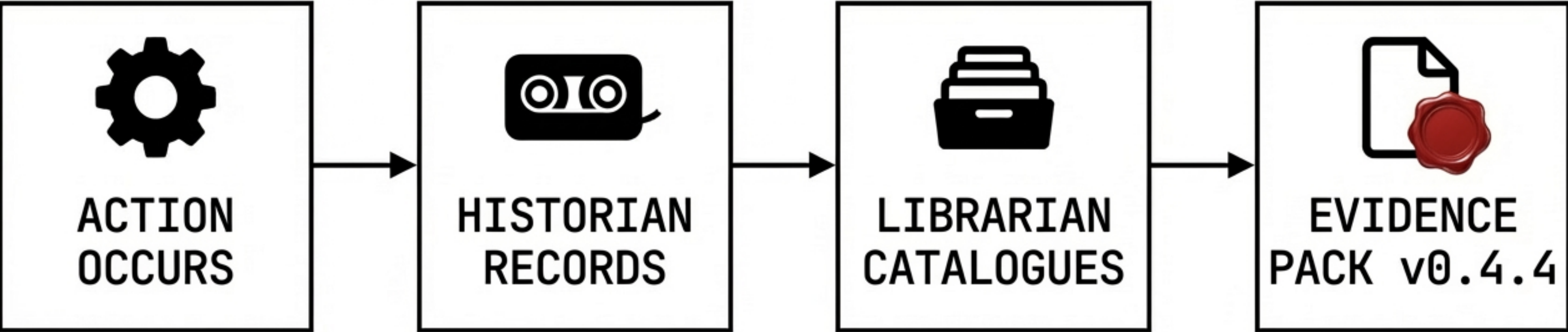
Industry theory suggests 'Shift Left' integrates security early. Often, this is aspirational—a feeling rather than a fact.

THE **REALITY** (OUR MISSION)

We rejected assumptions. We analysed SGraph Send project logs to extract concrete 'receipts'—specific instances where a DPO, AppSec, or GRC agent physically changed a decision.

> **CRITERIA: NO 'NEAR MISSES'. NO THEORETICAL BENEFITS. DOCUMENTED INTERVENTIONS ONLY.**

METHODOLOGY: THE FORENSIC AUDIT



SCOPE

Full review of v0.4.4
Evidence Pack.

AGENTS

Historian (Recording),
Librarian (Cataloguing),
Journalist (Verification).

CONSTRAINT

Evidence Only. Every claim
links to a specific
document version and quote.

EXHIBIT A: PRIVACY AS AN ARCHITECTURAL CONSTRAINT

ROLE FOCUS: DPO (Data Protection Officer)



The DPO didn't 'add' privacy; they made it the starting point.
The server never sees plaintext.

"Privacy by design worked — DPO role ensured no IP addresses captured in logs." (Source: v0.3.10)

EXHIBIT B: THE DEMAND FOR EMPIRICAL VERIFICATION

ROLE FOCUS: DPO + APPSEC

ENGINEERING OPTIMISM

☒ Logging Disabled

COMPLIANCE CERTAINTY

```
{  
  "timestamp": "2026-02-16T10:00:00Z",  
  "request_id": "req-123",  
  "client_ip": null  
}
```

We moved from 'we think it's off' to examining actual log data to confirm absence.
We moved from 'we think it's off' to examining actual log data to confirm absence.

"This needs to be confirmed empirically, not assumed." (Source: v0.4.3)

EXHIBIT C: STOPPING THE “GOOD IDEA”

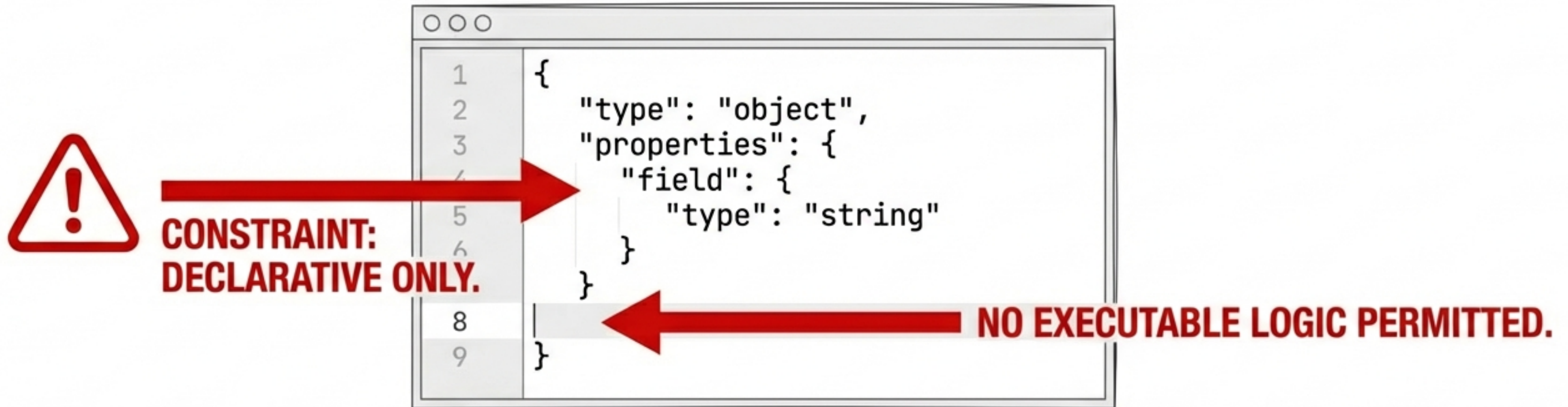
ROLE FOCUS: APPSEC



- **THE SCENARIO:** UX proposed “Three-word keys” for usability.
- **THE INTERVENTION:** AppSec flagged entropy risks immediately.
- **THE RESULT:** Feature parked for security review before code was written.

EXHIBIT D: PREVENTING INJECTION VIA DESIGN

ROLE FOCUS: APPSEC + ARCHITECT

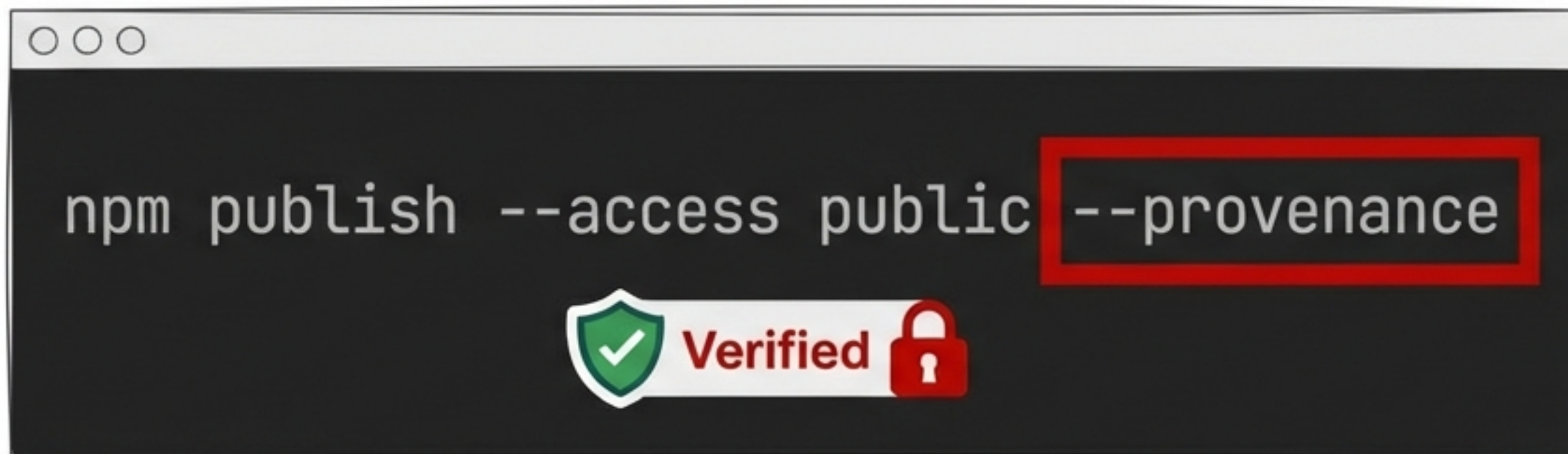


Risk: How do we ensure JSON schemas can't exfiltrate decrypted data?

Solution: Security defined the schema standard before implementation. Renderers must be sandboxed.

EXHIBIT E: HARDENING THE SUPPLY CHAIN

ROLE FOCUS: APPSEC + DEVOPS



- **NPM PROVENANCE:** Cryptographically linking packages to the GitHub commit.
- **PIPELINE REVIEW:** AppSec assigned specifically to review the publishing pipeline during bootstrap.
- **TAKEAWAY:** DevOps builds differently because AppSec is watching the pipe, not just the code.

EXHIBIT F: GLOBAL GOVERNANCE & MARKET ENTRY

ROLE FOCUS: GRC



TRANSLATION PROFILES: GRC ensured translation isn't just linguistic, but regulatory.

IMPACT: The product is 'Market-Ready' by default. The DP0 produces policies; the Translator localises legal meaning.

EXHIBIT G: OPERATIONAL DISCIPLINE

ROLE FOCUS: CISO + APPSEC

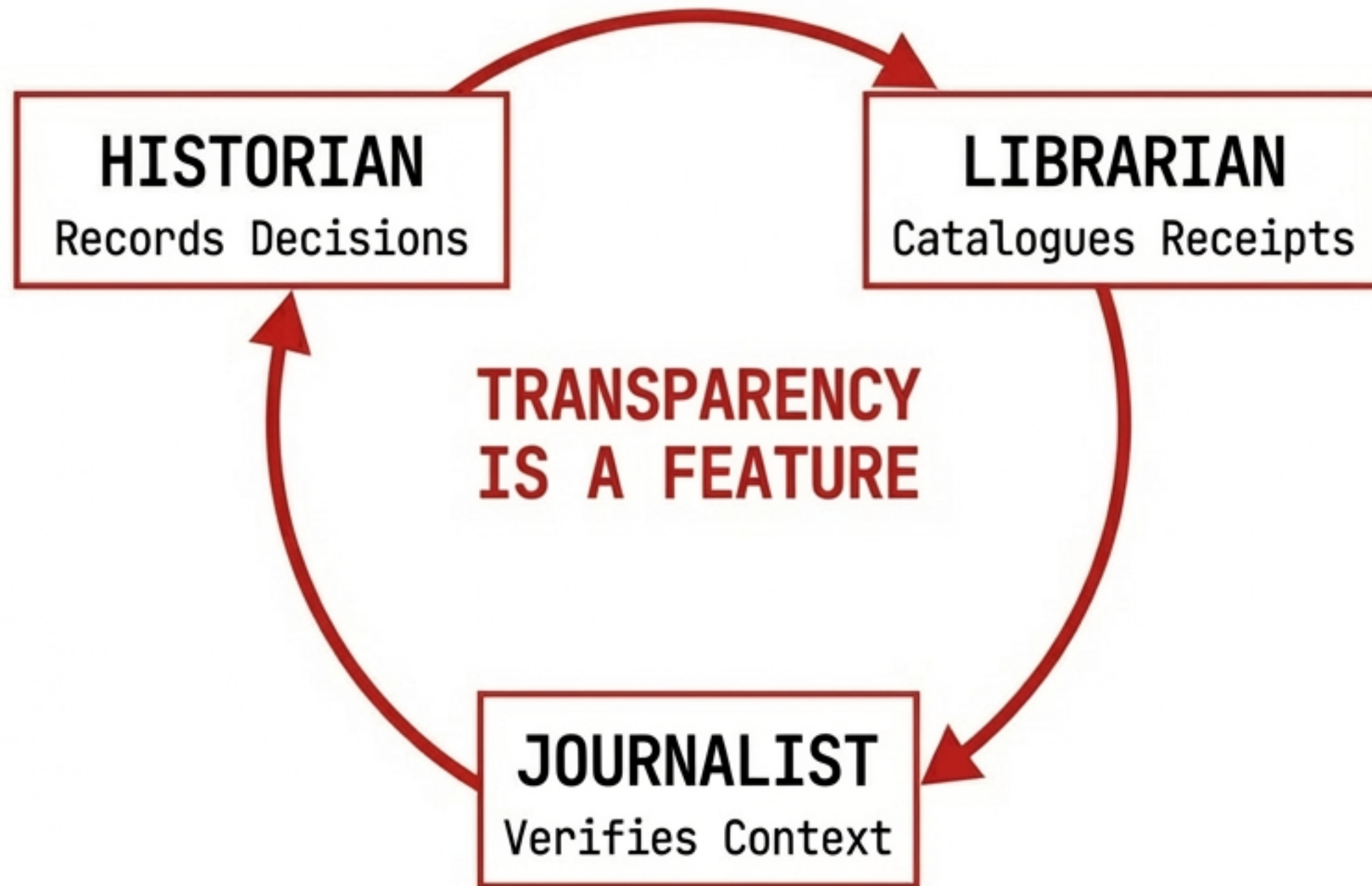


- THE RULE: For every change that touches production, risk assessment is mandatory.
- IMPACT: Risk assessment is not an optional meeting; it is a blocking state in the deployment state machine.

THE COUNTERFACTUAL ANALYSIS

DIMENSION	DEFAULT TRAJECTORY (WITHOUT ROLES)	ACTUAL OUTCOME (WITH ROLES)
PRIVACY	PII (IP addresses) stored in default logs.	✓ Zero-Knowledge, GDPR-compliant logging.
SECURITY	Weak 'three-word' keys shipped for UX.	✓ High-entropy keys; feature held for review.
SUPPLY CHAIN	Unverified NPM packages.	✓ Cryptographic provenance linked to source.
GLOBAL	Generic linguistic translations.	✓ Market-specific regulatory localisation.

THE META-INSIGHT: THE SYSTEM VALIDATES ITSELF



We know this works
because we have the
records.

We do not have to
'remember' to audit the
project; the project
audits itself in real-
time.

SUMMARY OF FINDINGS



STRATEGIC SHIFT:

FROM: REMEDIATION (Fixing later)
TO: PREVENTION (Fixing now)

A FORCE MULTIPLIER

Embedding DPO, AppSec, and GRC roles does not slow down development. It prevents the debt that kills projects later. The Agentic model doesn't just write code; it protects the organisation.

REVIEW THE FULL EVIDENCE PACK (v0.4.4)